



# Documentacion Tecnica del Sistema

Gestion de Tickets TI y Control de Acceso RBAC

Documento: STD-2026-TI | Generado: 24/8/2026, 8:14:37 a. m.

## 1. Resumen del sistema

Sistema centralizado de mesa de ayuda para el departamento de Tecnologias de la Informacion. Gestiona el ciclo de vida completo de incidencias y requerimientos garantizando trazabilidad total sobre quien solicito, quien atendio y quien resolvió cada ticket, sobre una arquitectura de seguridad basada en control de acceso por roles con asignacion dinamica de permisos.

### Componentes construidos

- API REST en Node.js con Express, autenticacion JWT y guard de permisos atomicos.
- Base de datos PostgreSQL con el esquema DDL de la especificacion mas bitacora y notificaciones.
- Canal de tiempo real con Socket.IO para notificaciones y actualizacion inmediata de tableros.
- Aplicacion web en React con Tailwind CSS e iconografia vectorial, sin uso de emojis.
- Aplicacion movil en React Native (Expo) que consume la misma API y el mismo canal de eventos.
- Motor documental PDF que emite actas, reportes y esta misma documentacion tecnica.
- Despliegue contenedorizado con Docker Compose para publicacion en servidor.

## 2. Arquitectura de la solucion

| CAPA          | TECNOLOGIA              | RESPONSABILIDAD                                                      |
|---------------|-------------------------|----------------------------------------------------------------------|
| Persistencia  | PostgreSQL 16           | Modelo relacional, integridad referencial y restricciones de dominio |
| Servicios     | Node.js 20 + Express    | API REST, reglas de negocio y control de acceso                      |
| Tiempo real   | Socket.IO               | Notificaciones y difusion de cambios por salas                       |
| Documental    | PDFKit                  | Actas, reportes y documentacion tecnica en PDF                       |
| Cliente web   | React 18 + Tailwind CSS | Interfaz administrativa y operativa                                  |
| Cliente movil | React Native (Expo)     | Atencion de tickets desde dispositivos moviles                       |
| Despliegue    | Docker Compose + Nginx  | Publicacion en servidor y proxy de API y sockets                     |



El token JWT es la unica fuente de identidad: el identificador del usuario nunca se acepta desde el cliente en las operaciones de creacion, atencion o resolucion de tickets.



### 3. Modelo de datos

Estructura fisica implementada segun la especificacion, ampliada con las tablas de bitacora de auditoria y de notificaciones necesarias para la trazabilidad documental y el canal de tiempo real.

| TABLA                  | PROPOSITO                                                            |
|------------------------|----------------------------------------------------------------------|
| areas                  | Catalogo de areas de la organizacion                                 |
| categorias             | Catalogo administrable de clasificacion de tickets                   |
| roles                  | Roles configurables desde el panel de administracion                 |
| permisos               | Permisos atomicos del sistema agrupados por modulo                   |
| rol_permisos           | Relacion N:M que materializa la matriz de permisos                   |
| usuarios               | Cuentas con area, rol, estado y hash bcrypt de la contrasena         |
| tickets                | Requerimientos con trazabilidad de solicitante, asignado y resolutor |
| auditoria              | Bitacora de cada accion ejecutada, base de los reportes PDF          |
| notificaciones         | Persistencia de los avisos emitidos por WebSockets                   |
| comentarios            | Conversacion entre solicitante y tecnico sobre el ticket             |
| adjuntos               | Capturas de pantalla y documentos asociados al ticket                |
| inventario_articulos   | Catalogo de articulos con su saldo vigente                           |
| inventario_movimientos | Kardex de entradas, salidas y ajustes                                |
| equipos                | Parque informatico, asignacion y acceso remoto cifrado               |
| sucursales             | Mapa de la empresa: casa central, plantas, sucursales y oficinas     |
| solicitudes_compra     | Pedidos de equipos con doble aprobacion y trazabilidad               |



La categoria del ticket dejo de ser una lista fija en el codigo: ahora se valida contra el catalogo administrable de la tabla categorias, mantenible desde el panel de administracion. Al renombrar una categoria el cambio se propaga a los tickets ya clasificados.

#### Esquema DDL implementado

```
CREATE TABLE IF NOT EXISTS areas (
  id SERIAL PRIMARY KEY,
  nombre VARCHAR(100) NOT NULL UNIQUE,
  activo BOOLEAN DEFAULT TRUE,
  fecha_creacion TIMESTAMP DEFAULT CURRENT_TIMESTAMP
);

CREATE TABLE IF NOT EXISTS roles (
  id SERIAL PRIMARY KEY,
  nombre VARCHAR(50) NOT NULL UNIQUE,
  descripcion TEXT,
  activo BOOLEAN DEFAULT TRUE
);
```

```

ð
CREATE TABLE IF NOT EXISTS permisos (ð
    id          SERIAL PRIMARY KEY,ð
    codigo      VARCHAR(100) NOT NULL UNIQUE,ð
    descripcion VARCHAR(255) NOT NULL,ð
    modulo      VARCHAR(50) NOT NULLð
);ð
ð
CREATE TABLE IF NOT EXISTS rol_permisos (ð
    rol_id      INT REFERENCES roles(id) ON DELETE CASCADE,ð
    permiso_id  INT REFERENCES permisos(id) ON DELETE CASCADE,ð
    PRIMARY KEY (rol_id, permiso_id)ð
);ð
ð
CREATE TABLE IF NOT EXISTS usuarios (ð
    id          SERIAL PRIMARY KEY,ð
    nombre      VARCHAR(150) NOT NULL,ð
    usuario     VARCHAR(80) NOT NULL UNIQUE,ð
    email       VARCHAR(150) UNIQUE,ð
    password_hash VARCHAR(255) NOT NULL,ð
    area_id     INT NOT NULL REFERENCES areas(id),ð
    rol_id      INT NOT NULL REFERENCES roles(id),ð
    activo      BOOLEAN DEFAULT TRUE,ð
    fecha_creacion TIMESTAMP DEFAULT CURRENT_TIMESTAMPð
);ð
ð
CREATE TABLE IF NOT EXISTS tickets (ð
    id          SERIAL PRIMARY KEY,ð
    titulo      VARCHAR(200) NOT NULL,ð
    descripcion TEXT NOT NULL,ð
    categoria   VARCHAR(50) NOT NULL,ð
    prioridad   VARCHAR(20) DEFAULT 'Media',ð
    estado      VARCHAR(20) DEFAULT 'Abierto',ð
    ð
    solicitante_id INT NOT NULL REFERENCES usuarios(id),ð
    asignado_id   INT REFERENCES usuarios(id),ð
    resuelto_por_id INT REFERENCES usuarios(id),ð
    ð
    solucion_detalle TEXT,ð
    fecha_creacion  TIMESTAMP DEFAULT CURRENT_TIMESTAMP,ð
    fecha_asignacion TIMESTAMP,ð
    fecha_resolucion TIMESTAMPð
);ð
ð
CREATE TABLE IF NOT EXISTS auditoria (ð
    id          SERIAL PRIMARY KEY,ð
    usuario_id  INT REFERENCES usuarios(id),ð
    entidad     VARCHAR(50) NOT NULL,ð
    entidad_id  INT,ð
    accion      VARCHAR(60) NOT NULL,ð
    detalle     JSONB,ð
    ip          VARCHAR(64),ð
    fecha       TIMESTAMP DEFAULT CURRENT_TIMESTAMPð
);ð
ð
CREATE TABLE IF NOT EXISTS notificaciones (ð
    id          SERIAL PRIMARY KEY,ð
    usuario_id  INT NOT NULL REFERENCES usuarios(id) ON DELETE CASCADE,ð
    ticket_id   INT REFERENCES tickets(id) ON DELETE CASCADE,ð
    tipo        VARCHAR(50) NOT NULL,ð
    titulo      VARCHAR(150) NOT NULL,ð
    mensaje     TEXT NOT NULL,ð
    leida       BOOLEAN DEFAULT FALSE,ð
    fecha       TIMESTAMP DEFAULT CURRENT_TIMESTAMPð
);ð

```

```

Ð
CREATE INDEX IF NOT EXISTS idx_tickets_estado          ON tickets(estado);Ð
CREATE INDEX IF NOT EXISTS idx_tickets_solicitante     ON tickets(solicitante_id);Ð
CREATE INDEX IF NOT EXISTS idx_tickets_asignado        ON tickets(asignado_id);Ð
CREATE INDEX IF NOT EXISTS idx_tickets_fecha          ON tickets(fecha_creacion DESC);Ð
CREATE INDEX IF NOT EXISTS idx_usuarios_area          ON usuarios(area_id);Ð
CREATE INDEX IF NOT EXISTS idx_auditoria_fecha         ON auditoria(fecha DESC);Ð
CREATE INDEX IF NOT EXISTS idx_notif_usuario_leida    ON notificaciones(usuario_id, leida);Ð
Ð
ALTER TABLE tickets DROP CONSTRAINT IF EXISTS chk_tickets_estado;Ð
ALTER TABLE tickets ADD CONSTRAINT chk_tickets_estadoÐ
    CHECK (estado IN ('Abierto', 'En Proceso', 'Resuelto', 'Cerrado'));Ð
Ð
ALTER TABLE tickets DROP CONSTRAINT IF EXISTS chk_tickets_prioridad;Ð
ALTER TABLE tickets ADD CONSTRAINT chk_tickets_prioridadÐ
    CHECK (prioridad IN ('Baja', 'Media', 'Alta', 'Critica'));

```

## 4. Diccionario de permisos atomicos

Permisos precargados en la base de datos. La interfaz de administracion construye los roles de forma dinamica a partir de este catalogo, agrupando las casillas de verificacion por modulo.

| MODULO     | CODIGO                 | DESCRIPCION DE LA ACCION                                          |
|------------|------------------------|-------------------------------------------------------------------|
| TICKETS    | tickets.crear          | Permite crear nuevas solicitudes de soporte.                      |
| TICKETS    | tickets.ver_propios    | Permite visualizar los tickets creados por el propio usuario.     |
| TICKETS    | tickets.ver_todos      | Permite visualizar el listado completo de tickets del sistema.    |
| TICKETS    | tickets.responder      | Permite asignarse un ticket y cambiar su estado a En Proceso.     |
| TICKETS    | tickets.resolver       | Permite cerrar/resolver un ticket e ingresar la solucion tecnica. |
| ADMIN      | admin.usuarios         | Gestion CRUD de usuarios (crear, editar, activar/desactivar).     |
| ADMIN      | admin.roles            | Gestion CRUD de roles y matriz de permisos.                       |
| ADMIN      | admin.areas            | Gestion del catalogo de areas de la empresa.                      |
| ADMIN      | admin.categorias       | Gestion del catalogo de categorias de tickets.                    |
| ADMIN      | admin.sucursales       | Gestion del catalogo de sucursales de la empresa.                 |
| REPORTES   | reportes.ver           | Permite consultar el tablero de indicadores y reportes.           |
| REPORTES   | reportes.exportar      | Permite exportar reportes y documentacion en formato PDF.         |
| INVENTARIO | inventario.ver         | Consultar el catalogo de articulos y el kardex de movimientos.    |
| INVENTARIO | inventario.articulos   | Gestion CRUD de los articulos del inventario.                     |
| INVENTARIO | inventario.movimientos | Registrar entradas y salidas de inventario.                       |
| EQUIPOS    | equipos.ver            | Consultar el parque de equipos y sus caracteristicas.             |
| EQUIPOS    | equipos.gestionar      | Alta, edicion y baja de equipos y su asignacion.                  |
| EQUIPOS    | equipos.credenciales   | Revelar la contrasena de acceso remoto de un equipo.              |
| COMPRAS    | compras.solicitar      | Registrar solicitudes de compra de equipos.                       |
| COMPRAS    | compras.ver_todas      | Consultar todas las solicitudes de compra.                        |
| COMPRAS    | compras.revisar        | Revisar la viabilidad tecnica y cotizar la solicitud.             |
| COMPRAS    | compras.aprobar        | Aprobar o rechazar la solicitud desde Gerencia.                   |
| COMPRAS    | compras.gestionar      | Registrar la compra ejecutada y la entrega.                       |

### Roles precargados

| ROL        | PERMISOS CONCEDIDOS                                                                         |
|------------|---------------------------------------------------------------------------------------------|
| admin      | Todos los permisos del sistema                                                              |
| tecnico_l1 | tickets.crear, ver_propios, ver_todos, responder, resolver, reportes.ver, reportes.exportar |
| tecnico_l2 | Identico a tecnico_l1, previsto para escalamiento                                           |
| cliente    | tickets.crear, tickets.ver_propios                                                          |

## 5. Control de acceso (middleware RBAC)

Cada endpoint valida el token JWT y luego evalua el guard de permisos. Los permisos vigentes del rol se resuelven contra la base de datos y se mantienen en una cache de corta duracion que se invalida al modificar la matriz de un rol, de modo que un cambio administrativo surte efecto de inmediato.

```
// Definicion de rutas protegidas
ticketsRouter.post('/',          requierePermiso('tickets.crear'),   crear);
ticketsRouter.put('/:id/tomar',  requierePermiso('tickets.responder'), tomar);
ticketsRouter.put('/:id/resolver', requierePermiso('tickets.resolver'), resolver);
rolesRouter.post('/',          requierePermiso('admin.roles'),      crearRol);

// Guard: exige al menos uno de los codigos indicados
export const requierePermiso = (...codigos) => (req, _res, next) => {
  const posee = codigos.some((codigo) => req.usuario.permisos.includes(codigo));
  if (!posee) return next(HttpError.forbidden());
  return next();
};
```

## → 6. Ciclo de vida del ticket

| ESTADO     | DISPARADOR                | EFECTOS REGISTRADOS                                                                         |
|------------|---------------------------|---------------------------------------------------------------------------------------------|
| Abierto    | POST /tickets             | solicitante_id = JWT.user_id; asignado_id y resuelto_por_id en NULL; fecha_creacion = NOW() |
| En Proceso | PUT /tickets/:id/tomar    | asignado_id = JWT.user_id; fecha_asignacion = NOW(); notificacion al solicitante            |
| En Proceso | PUT /tickets/:id/asignar  | asignado_id = tecnico elegido; notificacion al tecnico asignado                             |
| Resuelto   | PUT /tickets/:id/resolver | solucion_detalle registrada; resuelto_por_id = JWT.user_id; fecha_resolucion = NOW()        |
| Cerrado    | PUT /tickets/:id/cerrar   | Cierre conforme por el solicitante o la mesa de ayuda                                       |



Cada transicion registra su accion en la bitacora de auditoria, emite el evento correspondiente por WebSockets y archiva automaticamente un acta PDF del ticket en el repositorio documental.

## 7. Endpoints expuestos

Prefijo base de la API: /api/v1

| METODO | RUTA                     | PERMISO REQUERIDO               | DESCRIPCION                               |
|--------|--------------------------|---------------------------------|-------------------------------------------|
| POST   | /auth/login              | Publico                         | Autenticacion y emision del token JWT     |
| GET    | /auth/perfil             | Autenticado                     | Perfil, rol y permisos vigentes           |
| POST   | /auth/cambiar-password   | Autenticado                     | Cambio de contraseña propia               |
| GET    | /tickets                 | tickets.ver_propios / ver_todos | Listado con filtros y alcance por permiso |
| GET    | /tickets/tablero         | tickets.ver_propios / ver_todos | Indicadores y distribuciones              |
| POST   | /tickets                 | tickets.crear                   | Apertura de un ticket (estado Abierto)    |
| GET    | /tickets/:id             | tickets.ver_propios / ver_todos | Detalle con bitacora de acciones          |
| PUT    | /tickets/:id/tomar       | tickets.responder               | Autoasignacion y paso a En Proceso        |
| PUT    | /tickets/:id/asignar     | tickets.responder               | Asignacion manual a otro tecnico          |
| PUT    | /tickets/:id/resolver    | tickets.resolver                | Registro de la solucion tecnica           |
| PUT    | /tickets/:id/cerrar      | Solicitante o mesa de ayuda     | Cierre conforme del ticket                |
| GET    | /tickets/:id/pdf         | tickets.ver_propios / ver_todos | Acta PDF individual del ticket            |
| GET    | /tickets/reporte/pdf     | reportes.exportar               | Reporte consolidado en PDF                |
| GET    | /tickets/:id/comentarios | Participante del ticket         | Conversacion del ticket                   |

| METOD  | ruta                                  | PERMISO REQUERIDO             | DESCRIPCION                                           |
|--------|---------------------------------------|-------------------------------|-------------------------------------------------------|
| POST   | /tickets/:id/comentarios              | Participante del ticket       | Mensaje con hasta cinco adjuntos                      |
| GET    | /adjuntos/:id                         | Participante del ticket       | Descarga del archivo adjunto                          |
| GET    | /inventario/resumen                   | inventario.ver                | Indicadores del inventario                            |
| GET    | /inventario/articulos                 | inventario.ver                | Catalogo paginado con filtros                         |
| POST   | /inventario/articulos                 | inventario.articulos          | Alta de articulo con stock inicial cero               |
| PUT    | /inventario/articulos/:id             | inventario.articulos          | Edicion del articulo                                  |
| DELETE | /inventario/articulos/:id             | inventario.articulos          | Baja logica del articulo                              |
| POST   | /inventario/articulos/:id/movimientos | inventario.movimientos        | Entrada, salida o ajuste                              |
| PUT    | /inventario/articulos/:id/estado      | inventario.articulos          | Cambio de situacion del articulo                      |
| GET    | /inventario/movimientos               | inventario.ver                | Kardex paginado                                       |
| GET    | /inventario/reporte/pdf               | inventario.ver                | Reporte del catalogo en PDF                           |
| GET    | /inventario/articulos/:id/kardex/pdf  | inventario.ver                | Kardex del articulo en PDF                            |
| GET    | /equipos                              | equipos.ver                   | Parque informatico paginado con filtros               |
| POST   | /equipos                              | equipos.gestionar             | Alta de equipo y su asignacion                        |
| PUT    | /equipos/:id                          | equipos.gestionar             | Edicion del equipo                                    |
| DELETE | /equipos/:id                          | equipos.gestionar             | Baja logica del equipo                                |
| GET    | /equipos/:id/credenciales             | equipos.credenciales          | Revela la contrasena remota, con registro en bitacora |
| GET    | /equipos/reporte/pdf                  | equipos.ver                   | Reporte del parque en PDF                             |
| GET    | /equipos/:id/ficha/pdf                | equipos.ver                   | Ficha tecnica del equipo en PDF                       |
| GET    | /sucursales                           | Autenticado                   | Catalogo de sucursales                                |
| POST   | /sucursales                           | admin.sucursales              | Alta de sucursal u oficina                            |
| GET    | /compras                              | compras.solicitar / ver_todas | Solicitudes con alcance por permiso                   |
| POST   | /compras                              | compras.solicitar             | Registro del pedido de equipo                         |
| PUT    | /compras/:id/revisar                  | compras.revisar               | Revision tecnica y cotizacion                         |
| PUT    | /compras/:id/aprobar-ti               | compras.revisar               | Aprobacion tecnica, eleva a Gerencia                  |
| PUT    | /compras/:id/aprobar-gerencia         | compras.aprobar               | Aprobacion presupuestaria                             |
| PUT    | /compras/:id/rechazar                 | compras.revisar / aprobar     | Rechazo con motivo                                    |
| PUT    | /compras/:id/comprar                  | compras.gestionar             | Registro de la compra ejecutada                       |



| METOD  | ruta                       | PERMISO REQUERIDO             | DESCRIPCION                                      |
|--------|----------------------------|-------------------------------|--------------------------------------------------|
| PUT    | /compras/:id/entregar      | compras.gestionar             | Entrega y vinculo con el parque                  |
| GET    | /areas                     | Autenticado                   | Catalogo de areas                                |
| POST   | /areas                     | admin.areas                   | Alta de area                                     |
| PUT    | /areas/:id                 | admin.areas                   | Edicion de area                                  |
| DELETE | /areas/:id                 | admin.areas                   | Baja logica de area                              |
| GET    | /roles                     | admin.roles / admin.usuarios  | Roles con su matriz de permisos                  |
| POST   | /roles                     | admin.roles                   | Creacion de rol con permisos                     |
| PUT    | /roles/:id                 | admin.roles                   | Reemplazo integral de la matriz del rol          |
| DELETE | /roles/:id                 | admin.roles                   | Eliminacion de rol sin usuarios                  |
| GET    | /permisos                  | admin.roles                   | Catalogo de permisos agrupado por modulo         |
| GET    | /categorias                | Autenticado                   | Catalogo de categorias de ticket                 |
| POST   | /categorias                | admin.categorias              | Alta de categoria con color e icono              |
| PUT    | /categorias/:id            | admin.categorias              | Edicion con propagacion del nombre a los tickets |
| DELETE | /categorias/:id            | admin.categorias              | Baja logica de categoria                         |
| GET    | /usuarios                  | admin.usuarios                | Listado con filtros                              |
| GET    | /usuarios/tecnicos         | tickets.ver_todos             | Tecnicos disponibles para asignacion             |
| POST   | /usuarios                  | admin.usuarios                | Alta de usuario con hash bcrypt                  |
| PUT    | /usuarios/:id              | admin.usuarios                | Edicion de usuario                               |
| DELETE | /usuarios/:id              | admin.usuarios                | Baja logica de usuario                           |
| GET    | /notificaciones            | Autenticado                   | Bandeja de notificaciones propias                |
| PUT    | /notificaciones/:id/leida  | Autenticado                   | Marcado individual como leida                    |
| GET    | /auditoria                 | reportes.ver / admin.usuarios | Bitacora de acciones                             |
| GET    | /auditoria/pdf             | reportes.exportar             | Bitacora de auditoria en PDF                     |
| GET    | /auditoria/matriz-rbac/pdf | admin.roles                   | Matriz de roles y permisos en PDF                |

## 8. Canal de tiempo real

El socket se autentica con el mismo token JWT en el handshake. Cada usuario se une a una sala personal y los perfiles con permiso tickets.ver\_todos se incorporan ademas a la sala del equipo tecnico.

| EVENTO                | DIRECCION          | DESCRIPCION                                                  |
|-----------------------|--------------------|--------------------------------------------------------------|
| conexion:establecida  | Servidor a cliente | Confirma la autentificacion del socket y las salas asignadas |
| ticket:suscribir      | Cliente a servidor | Suscribe al canal de un ticket especifico                    |
| ticket:desuscribir    | Cliente a servidor | Abandona el canal de un ticket                               |
| ticket:creado         | Servidor a cliente | Nuevo ticket registrado en la mesa de ayuda                  |
| ticket:actualizado    | Servidor a cliente | Cambio de estado, asignacion o cierre                        |
| ticket:resuelto       | Servidor a cliente | Registro de la solucion tecnica                              |
| notificacion:nueva    | Servidor a cliente | Notificacion personal para el destinatario                   |
| comentario:nuevo      | Servidor a cliente | Mensaje nuevo en la conversacion del ticket                  |
| inventario:movimiento | Servidor a cliente | Entrada o salida registrada en el inventario                 |
| compra:creada         | Servidor a cliente | Nueva solicitud de compra registrada                         |
| compra:actualizada    | Servidor a cliente | Avance de la solicitud en el circuito                        |

## 9. Modulo de documentacion en PDF

Todas las salidas documentales del sistema se generan con un unico motor que garantiza identidad visual uniforme: encabezado institucional, iconografia vectorial, tablas con encabezado repetido y pie de pagina con la autoria del modulo en cada hoja. No se emplean emojis en ningun documento.

| DOCUMENTO                  | ORIGEN                               | MOMENTO DE EMISION                           |
|----------------------------|--------------------------------------|----------------------------------------------|
| Acta de ticket             | GET /tickets/:id/pdf                 | Bajo demanda y automatica en cada transicion |
| Reporte de gestion         | GET /tickets/reporte/pdf             | Bajo demanda con los filtros vigentes        |
| Bitacora de auditoria      | GET /auditoria/pdf                   | Bajo demanda por periodo y entidad           |
| Matriz de roles y permisos | GET /auditoria/matriz-rbac/pdf       | Bajo demanda desde el panel de roles         |
| Documentacion tecnica      | node docs/generator/generate-docs.js | En cada actualizacion del sistema            |

### Iconografia disponible en los documentos

- ✓ ticket, usuario, escudo y engranaje para identidad de modulos y secciones.
- ✓ reloj, check y alerta para estados, cumplimiento y prioridades criticas.
- ✓ documento, grafico, baseDatos, flujo y red para reportes y arquitectura.

## 10. Modulo de inventario de sistemas

---

El inventario mantiene el catalogo de articulos y el kardex de movimientos. El saldo de un articulo nunca se edita de forma directa: resulta exclusivamente de las entradas, salidas y ajustes registrados, cada uno con su saldo anterior y resultante.

- Entrada: incrementa el saldo. Se emplea en compras y devoluciones al deposito.
- Salida: descuenta el saldo y se rechaza si no alcanza el stock disponible.
- Ajuste: fija el saldo en la cantidad indicada, para recuentos fisicos.
- El movimiento puede asociarse a un ticket, dejando trazabilidad del consumo.
- La fila del articulo se bloquea durante la transaccion, de modo que dos movimientos simultaneos no dejan un saldo erroneo.
- Al caer por debajo del minimo definido se avisa al equipo tecnico.
- Cada articulo lleva ademas su situacion: Disponible, En reparacion, En resguardo o De baja.
- Darlo de baja lo retira de los activos y le impide admitir movimientos; volver a Disponible lo reactiva.

### Limites de carga de los listados

Todos los listados extensos del sistema responden paginados. El limite por defecto es de 25 registros y el maximo admitido es de 200, acotado en el servidor: un cliente no puede solicitar la tabla completa y saturar la memoria del navegador ni la del servidor.

## 11. Modulo de equipos de la empresa

Registra el parque informatico con su asignacion por usuario y area, las características técnicas de cada maquina y los datos de acceso remoto empleados por la mesa de ayuda.

| GRUPO DE DATOS  | CONTENIDO                                                          |
|-----------------|--------------------------------------------------------------------|
| Identificacion  | Codigo, nombre del equipo, tipo, marca, modelo y numero de serie   |
| Caracteristicas | Sistema operativo, procesador, memoria RAM y almacenamiento        |
| Conectividad    | Direccion IP y direccion MAC, ambas validadas por formato          |
| Acceso remoto   | Identificador de AnyDesk y contraseña cifrada                      |
| Asignacion      | Usuario responsable, area, ubicacion, estado y fecha de asignacion |

### Tratamiento de la contraseña de acceso remoto

- Se almacena cifrada con AES-256-GCM, nunca en texto plano.
- La clave se deriva por script de la semilla definida en la variable CLAVE\_CIFRADO.
- La etiqueta de autenticidad permite detectar cualquier alteracion del dato guardado.
- No viaja en los listados: la respuesta solo informa si existe contraseña registrada.
- Revelarla exige el permiso equipos.credenciales y queda asentado en la bitacora con usuario y fecha.
- Ningun documento PDF exportable incluye contraseñas.



Al perder la semilla CLAVE\_CIFRADO las contraseñas guardadas dejan de poder descifrarse y deben registrarse nuevamente. Conservela junto con el resto de los secretos del despliegue.

## 12. Sucursales y circuito de compras

El usuario pertenece a una sucursal y a un area, ambas independientes: las mismas areas funcionales existen en varias sucursales, de modo que separarlas evita duplicar el catalogo y permite cortar los indicadores por cualquiera de las dos dimensiones. El ticket, el equipo y la solicitud de compra heredan la sucursal de quien los origina, sin preguntarla.

| CODIGO             | SUCURSAL                          | TIPO                      |
|--------------------|-----------------------------------|---------------------------|
| SCZ                | Fabrica Santa Cruz                | Fabrica, sede del sistema |
| SILO               | Silos Central de Insumos          | Planta                    |
| LP, CBBA, SRE, ORU | La Paz, Cochabamba, Sucre y Oruro | Sucursales                |



El catalogo es administrable: las oficinas futuras, como Distribucion Central o Venta Privada, se agregan desde el panel sin intervenir el codigo.

### Circuito de la solicitud de compra

| ESTADO                | QUIEN ACTUA   | QUE OCURRE                                   |
|-----------------------|---------------|----------------------------------------------|
| Solicitada            | Solicitante   | Registra el pedido con su justificacion      |
| En revision           | TI            | Evalua la viabilidad tecnica y cotiza        |
| Aprobada por TI       | TI            | Da el visto bueno tecnico y eleva a Gerencia |
| Aprobada por Gerencia | Gerencia      | Aprueba el presupuesto                       |
| Comprada              | TI            | Registra la orden de compra y el monto final |
| Entregada             | TI            | Entrega el equipo y lo vincula al parque     |
| Rechazada             | TI o Gerencia | Rechaza con motivo, antes de la compra       |



El orden del circuito se valida en el servidor: Gerencia no puede aprobar antes que TI, ni se puede registrar una compra sin aprobacion previa.



## 13. Seguridad de la plataforma

La credencial de sesion no se guarda en el almacenamiento del navegador. Al iniciar sesion el servidor deja dos cookies complementarias: una de sesion marcada httpOnly, que ningun script de la pagina puede leer, y una segunda de verificacion de origen que la aplicacion si lee y reenvia por cabecera en cada operacion de escritura. Un sitio ajeno puede provocar que el navegador envíe la cookie de sesion, pero no puede leer la segunda para reproducir la cabecera, de modo que la peticion se rechaza.

| CONTROL                                   | RIESGO QUE ATIENDE                                                               | IMPLEMENTACION                                                                               |
|-------------------------------------------|----------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------|
| Sesion en cookie httpOnly                 | Robo de la credencial por codigo inyectado en la pagina                          | El token viaja en una cookie que ningun script puede leer, con SameSite estricto             |
| Verificacion de origen                    | Peticiones forjadas desde otro sitio ya abierto en el navegador                  | Doble envio: cookie legible mas cabecera X-CSRF-Token, comparadas en tiempo constante        |
| Bloqueo por cuenta                        | Adivinacion de contraseñas rotando la direccion de origen                        | Cinco fallos en quince minutos bloquean el usuario otros quince, sin inhabilitar la cuenta   |
| Freno por origen                          | Saturacion del servicio y fuerza bruta masiva                                    | Trescientas peticiones por minuto y cuarenta intentos fallidos de acceso cada diez minutos   |
| Retardo progresivo                        | Automatismos que prueban claves de forma sistematica                             | Desde el quinto fallo cada intento responde medio segundo mas lento, hasta cinco segundos    |
| Origen declarado                          | Escrituras emitidas desde un sitio ajeno o desde un guion que no es un navegador | Toda escritura con cookie debe partir de un origen de la lista autorizada                    |
| Acceso cerrado por omision                | Una ruta nueva publicada sin guardia por descuido                                | La API exige credencial salvo en las rutas declaradas abiertas de forma explicita            |
| Rol de base sin privilegios de estructura | Que una falla de inyeccion alcance a destruir o alterar las tablas               | La API se conecta con un rol que solo lee y escribe filas, no dueño del esquema              |
| Conexiones cifradas                       | Lectura de la sesion en cualquier punto intermedio de la red                     | Con FORZAR_HTTPS las lecturas se reconducen a HTTPS y las escrituras en claro se rechazan    |
| Cabeceras de proteccion                   | Enmarcado del sitio, interpretacion indebida de archivos y fuga por el referente | Politica de contenido restrictiva, nosniff, SAMEORIGIN, referente suprimido y HSTS           |
| Cifrado de credenciales                   | Exposicion de las claves de acceso remoto guardadas                              | AES-256-GCM con clave derivada por scrypt; se revelan solo bajo peticion autorizada          |
| Validacion de entrada                     | Datos malformados, inyeccion y cuerpos desmedidos                                | Esquemas declarativos por endpoint, consultas parametrizadas y cuerpo limitado a un megabyte |
| Rastro de auditoria                       | Acciones sin responsable identificable                                           | Cada operacion de escritura deja usuario, entidad, accion, direccion de origen y momento     |
| Secretos obligatorios                     | Publicacion con las claves del archivo de ejemplo                                | El arranque en produccion se detiene si un secreto conserva el valor de muestra              |

### Circuito de la sesion

```
// Inicio de sesion
Set-Cookie: tickets_sesion=<token>; HttpOnly; SameSite=Strict; Secure; Path=/
Set-Cookie: tickets_csrf=<token de origen>; SameSite=Strict; Secure; Path=/

// Toda escritura desde el navegador
X-CSRF-Token: <token de origen> // debe coincidir con la cookie

// La aplicacion movil conserva el esquema con cabecera,
// que no es explotable por peticiones forjadas entre sitios
Authorization: Bearer <token>
```



En produccion el servicio se niega a arrancar si JWT\_SECRET, CLAVE\_CIFRADO o la contraseña de la base de datos conservan el valor de ejemplo o tienen menos de 24 caracteres.

## La API no se conecta como dueña de las tablas

La aplicacion trabaja con un rol de privilegios recortados que solo puede leer, insertar, modificar y borrar filas. No puede crear, alterar ni destruir tablas, ni vaciarlas de un golpe, ni crear roles. De ese modo una eventual falla de inyeccion queda acotada a los datos y no alcanza a la estructura. El rol se crea con "npm run privilegios" y las tablas que se agreguen en el futuro heredan el mismo criterio.

## Sobre la seguridad por fila

La seguridad por fila de PostgreSQL tiene sentido cuando el cliente habla directamente con la base de datos, porque ahí es la unica frontera que queda. En esta instalacion la base nunca es alcanzable por el cliente: la API es la unica puerta y la autorizacion se decide en ella, con permisos atomicos por endpoint y verificacion de propiedad sobre cada registro.

Hay ademas un detalle tecnico determinante: el dueño de una tabla omite las politicas de seguridad por fila salvo que se declaren forzadas. Mientras la aplicacion se conectara con la cuenta propietaria, activarlas habria dado una falsa sensacion de proteccion sin efecto real. Por eso se opto por quitarle esa propiedad, que es el requisito previo y aporta mas por si solo. El rol de trabajo queda preparado con NOBYPASSRLS, de modo que si en el futuro se decide exponer la base a algun cliente, basta con agregar las politicas y fijar la identidad del usuario por transaccion.

## Proteccion contra automatismos

No se emplea un desafio visual de terceros: obligaria a cargar codigo externo, romperia la politica de contenido y entregaria el trafico de la empresa a un proveedor ajeno. En su lugar actuan tres controles propios que castigan unicamente el fracaso, de modo que quien entra bien no los nota: el retardo progresivo, el bloqueo por cuenta y la exigencia de un origen declarado y autorizado.

## Aprovechamiento de cache

Los catalogos que se consultan en casi toda navegacion y cambian pocas veces (areas, sucursales y categorias) se resuelven desde una cache en memoria de dos minutos y se acompanan de una cabecera Cache-Control privada con etiqueta de entidad. Una consulta repetida se resuelve con un 304 sin volver a transferir el cuerpo. Toda escritura sobre un catalogo descarta su clave, de modo que un cambio administrativo se ve de inmediato y no queda a la espera de que venza un plazo.



## 14. Verificacion y resultado de las pruebas

El repositorio incorpora una bateria de pruebas automatizadas que recorre el sistema de extremo a extremo contra la API en ejecucion. Se invocan con "npm run qa" desde la carpeta backend y dejan la base sin residuos mediante "npm run qa:limpiar".

| BATERIA     | QUE COMPRUEBA                                                                                                                                                                                                    | RESULTADO |
|-------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------|
| Secretos    | Configuracion fuera del control de versiones, historial completo del repositorio, credenciales incrustadas en el codigo y valores del archivo de ejemplo                                                         | 7 de 7    |
| Seguridad   | Cookies de sesion, verificacion del origen declarado, cabeceras, bloqueo por intentos, cache, acceso cerrado por omision y cierre de sesion                                                                      | 34 de 34  |
| Funcional   | Acceso de las once cuentas, catalogos, ciclo completo del ticket, inventario, equipos, compras con doble aprobacion, tablero, notificaciones, auditoria, paginacion, ocho documentos PDF y validacion de entrada | 70 de 70  |
| Tiempo real | Ingreso al canal, reparto por salas, aviso inmediato de un ticket nuevo y rechazo de conexiones sin sesion                                                                                                       | 4 de 4    |

### Puntos pendientes conocidos

Los siguientes puntos no son defectos del sistema construido, sino trabajo que corresponde a la puesta en produccion o a alcances no solicitados hasta ahora. Se dejan enumerados para que la decision sobre cada uno quede documentada.

| PUNTO PENDIENTE                     | SITUACION ACTUAL                                                                                                                                                      | PRIORIDAD                       |
|-------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------|
| Aplicacion movil                    | El codigo esta escrito y consume la API con cabecera Authorization, pero no se ha compilado ni probado sobre un dispositivo real                                      | Alta si se quiere usar en campo |
| Certificado HTTPS                   | El reconducido a HTTPS y la cookie segura estan implementados; falta el certificado. Sin el hay que desactivarlos de forma explicita con FORZAR_HTTPS y COOKIE_SECURE | Alta antes de publicar          |
| Dependencias de la aplicacion movil | Nunca se instalaron, de modo que no se pudo auditar su arbol de dependencias                                                                                          | Media                           |
| Revision periodica de dependencias  | La auditoria esta limpia hoy, pero no hay revision automatica que avise de un aviso nuevo                                                                             | Media                           |
| Revocacion de sesiones              | El token es valido hasta su vencimiento; desactivar un usuario no corta la sesion ya abierta                                                                          | Media                           |
| Estado compartido entre instancias  | La cache, el bloqueo por intentos y el freno por origen viven en memoria del proceso: con varias instancias haria falta un almacen comun                              | Media si se escala              |
| Cambio de clave obligatorio         | Las cuentas se entregan con una contrasena inicial conocida y el sistema no exige cambiarla al primer ingreso                                                         | Media                           |
| Aviso por correo                    | Los avisos llegan por el canal en tiempo real y por la bandeja interna, no por correo electronico                                                                     | Baja                            |

| PUNTO PENDIENTE              | SITUACION ACTUAL                                                                            | PRIORIDAD              |
|------------------------------|---------------------------------------------------------------------------------------------|------------------------|
| Respaldo de la base de datos | No hay tarea programada de respaldo ni prueba de restauracion                               | Alta antes de publicar |
| Pruebas unitarias            | La verificacion es de extremo a extremo contra la API; no hay pruebas unitarias por funcion | Baja                   |

## 15. Despliegue en servidor

La solucion se publica con Docker Compose. La base de datos aplica automaticamente el esquema y la carga inicial en su primer arranque; la aplicacion web se sirve mediante Nginx, que ademas actua como proxy de la API y del canal de WebSockets.

```
cp .env.example .env          # definir credenciales y JWT_SECRET
docker compose build
docker compose up -d

# Servicios publicados
web -> http://localhost:8080
api -> http://localhost:4000/api/v1
salud -> http://localhost:4000/salud
```



Antes de publicar en produccion es obligatorio reemplazar JWT\_SECRET y la contrasena de la base de datos, y cambiar la clave del usuario administrador inicial.

### Ejecucion en entorno de desarrollo

```
# 1. Base de datos (PostgreSQL local)
createdb tickets_ti
cd backend && npm install && npm run migrate

# 2. API
npm run dev

# 3. Aplicacion web
cd ../frontend && npm install && npm run dev

# 4. Aplicacion movil
cd ../mobile && npm install && npm start
```

## 16. Inventario de componentes

| COMPONENTE    | RUTA                  | CONTENIDO                                      |
|---------------|-----------------------|------------------------------------------------|
| Base de datos | db/01_schema.sql      | Esquema DDL completo e indices                 |
| Base de datos | db/02_seed.sql        | Areas, roles, permisos y usuario administrador |
| Base de datos | db/03_categorias.sql  | Catalogo administrable de categorias           |
| Base de datos | db/04_comentarios.sql | Conversacion y adjuntos del ticket             |
| Base de datos | db/05_inventario.sql  | Articulos y kardex de movimientos              |
| Base de datos | db/06_equipos.sql     | Parque de equipos de la empresa                |

| COMPONENTE    | RUTA                             | CONTENIDO                                             |
|---------------|----------------------------------|-------------------------------------------------------|
| Base de datos | db/07_estado_articulos.sql       | Situacion del articulo de inventario                  |
| Base de datos | db/08_sucursales.sql             | Sucursales y ubicacion de usuarios, tickets y equipos |
| Base de datos | db/09_compras.sql                | Solicitudes de compra con doble aprobacion            |
| Base de datos | db/10_fabrica.sql                | La sede de Santa Cruz como fabrica                    |
| API           | backend/src/modules/compras/     | Circuito de adquisiciones de equipos                  |
| API           | backend/src/modules/equipos/     | Parque informatico y credenciales de acceso remoto    |
| API           | backend/src/utills/cifrado.js    | Cifrado AES-256-GCM de credenciales                   |
| API           | backend/src/modules/inventario/  | Catalogo, movimientos y reportes de inventario        |
| API           | backend/src/utills/paginacion.js | Limites de carga uniformes de los listados            |
| API           | backend/src/app.js               | Composicion de middlewares y montaje de rutas         |
| API           | backend/src/server.js            | Servidor HTTP, sockets y apagado ordenado             |
| API           | backend/src/middleware/auth.js   | Verificacion JWT para HTTP y para sockets             |
| API           | backend/src/middleware/rbac.js   | Guard RequierePermiso sobre permisos atomicos         |
| API           | backend/src/modules/tickets/     | Ciclo de vida completo del ticket                     |
| API           | backend/src/realtime/socket.js   | Canal de tiempo real y gestion de salas               |
| API           | backend/src/services/pdf/        | Motor documental: iconos, plantilla y reportes        |
| Web           | frontend/src/context/            | Sesion, permisos y notificaciones en vivo             |
| Web           | frontend/src/pages/              | Tablero, tickets, administracion y auditoria          |
| Movil         | mobile/src/screens/              | Pantallas Expo con el mismo modelo de permisos        |
| Despliegue    | docker-compose.yml               | Orquestacion de base de datos, API y web              |

 17. Acceso inicial y control de versiones

USUARIO ADMINISTRADOR

admin

CONTRASENA INICIAL

Definida al instalar, minimo diez caracteres

AREA ASIGNADA

Tecnologias de la Informacion

ROL ASIGNADO

admin

| VERSION | FECHA      | DESCRIPCION                                                 | RESPONSABLE            |
|---------|------------|-------------------------------------------------------------|------------------------|
| 1.0.0   | 18/08/2026 | Construccion inicial completa del sistema segun STD-2026-TI | Ing. Edgar Rojas Apaza |

| VERSION | FECHA      | DESCRIPCION                                                                                                                                                                            | RESPONSABLE            |
|---------|------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------|
| 1.7.0   | 20/08/2026 | Sucursales, circuito de compras con doble aprobacion, inventario y equipos                                                                                                             | Ing. Edgar Rojas Apaza |
| 1.7.2   | 20/08/2026 | Legibilidad de los documentos PDF y constancia de la aprobacion de Gerencia                                                                                                            | Ing. Edgar Rojas Apaza |
| 1.8.0   | 21/08/2026 | Sesion en cookie httpOnly con verificacion de origen, cache de catalogos, bloqueo por intentos fallidos, secretos obligatorios en produccion y bateria de pruebas automatizadas        | Ing. Edgar Rojas Apaza |
| 1.9.0   | 21/08/2026 | Rol de base sin privilegios de estructura, API cerrada por omision, verificacion del origen declarado, retardo progresivo ante automatismos, reconducido a HTTPS y rastreo de secretos | Ing. Edgar Rojas Apaza |
| 1.11.0  | 21/08/2026 | Recorrido visible de la solicitud de compra, actualizacion en tiempo real para Gerencia, importes en bolivianos y revision tecnica centrada en sugerir el equipo                       | Ing. Edgar Rojas Apaza |
| 2.0.0   | 21/08/2026 | Arquitectura por modulos, tabla declarativa de rutas y codigo sin comentarios                                                                                                          | Ing. Edgar Rojas Apaza |
| 2.1.0   | 22/08/2026 | Reporte mensual de la mesa de ayuda en el tablero, Gerencia habilitada para registrar tickets y bitacora de auditoria con permiso propio                                               | Ing. Edgar Rojas Apaza |
| 2.2.2   | 23/08/2026 | Reporte mensual detallado con filtros, correccion del desborde de paginas en los PDF y calendario para elegir el periodo                                                               | Ing. Edgar Rojas Apaza |
| 2.3.0   | 24/8/2026  | Modulo de peticiones de proyecto, politica de contraseñas con cambio y restablecimiento, base reiniciada a una sola cuenta administradora y baterias de prueba autosuficientes         | Ing. Edgar Rojas Apaza |